

The Budget That Was Never Denied:

How Cybersecurity's Communication Crisis Turns Prevention into Catastrophe

By Godfrey Kutumela, CEO and Lead Cybersecurity Practitioner, Nucleus Systems — June 2026

Risk Governance | Board Advisory | Cybersecurity Risk Management | CISO Leadership

ABOUT THIS POSITION PAPER

Modern organizations continue to repeat one of the most expensive patterns in cybersecurity: they underfund prevention, suffer a major cyber incident, spend several times more on recovery, then briefly re-prioritize cybersecurity before returning to the same cycle of underinvestment. This paper names that pattern for what it is, and argues for what must change.

This pattern is widely described as a budget problem. It is not. At its core, it is a communication and governance problem. And that distinction changes everything about how it should be solved.

This position paper examines the structural, cultural, and governance failures that produce this cycle. It draws on a representative ransomware scenario, maps those failures against established international standards and risk management frameworks, and provides detailed recommendations for organizations seeking to break the pattern before the next preventable loss forces them to do so.

The paper is structured around five interlocking arguments:

- Cybersecurity's communication failure is not a language problem alone. It is a governance architecture failure that leaves risk undocumented, unowned, and unaccountable, until an incident forces accountability at the worst possible moment.
- The frameworks and standards that would have prevented the described scenario already exist, are widely available, and are increasingly adopted by mature organizations. The gap is not knowledge. It is an implementation at the governance layer.
- Boards that deny material cybersecurity investment requests without formal risk acceptance are not making budget decisions. They are making risk-acceptance decisions without realizing it, and that distinction carries significant fiduciary weight.
- The six governance failures described in this paper are individually correctable. Together they constitute a systemic failure pattern that, once named and mapped to its remedies, becomes significantly easier to address.
- The future of cybersecurity leadership belongs to practitioners who communicate in the language of business consequence, not technical capability, and who build governance structures that force accountability before events make it unavoidable.

"Security budgets are not only financial decisions. They are risk governance decisions. Nobody denies a risk they are forced to own formally."

KEY NARRATIVES SYNTHESIZED IN THIS PAPER

- The security budget paradox → Prevention is theoretical, so it is deferred. Recovery is real, so it is funded. That asymmetry is a governance design flaw, not a financial inevitability.
- Documentation is not understood → A risk buried in a budget submission is not a risk accepted by a board. The gap between those two conditions is where organizations are most dangerously exposed.
- The frameworks exist, but are not embedded → NIST CSF 2.0, FAIR, COSO ERM, ISO 27001, and ISO 31000 each address this failure mode directly. They are not being applied at the governance layer where they are needed most.
- Risk ownership must move upstream → Cyber risk materializes in business operations. It must be owned by business leaders, not delegated entirely to the CISO.
- The governance shift that changes everything → Requiring formal risk acceptance for every denied material control is the highest-leverage single governance change available to any organization.

I. The Scenario: A Story That Has Already Happened Somewhere Near You

The following scenario is not hypothetical in the way most thought experiments are. It is a composite drawn from documented patterns observed across multiple industries and geographies. It almost certainly describes an experience that has already occurred, or is occurring right now, in an organization similar to yours.

A CISO submitted a cybersecurity budget request for \$1.2 million. The request covered three areas: endpoint detection across all organizational devices, identity governance to address orphaned and over-privileged accounts, and a third-party risk programme for vendors with access to internal systems. Each area had been identified through a formal risk assessment. Each carried documented threat scenarios. Each had been costed with reasonable specificity. The request was denied. The reason given was familiar.

“We need stronger business justification.”

Seven months later, the company suffered a ransomware attack. The recovery cost was \$4.7 million. The board convened an emergency session, and by the end of that meeting, the CISO had been handed \$3 million in unbudgeted emergency funding. No business justification was required this time.

Later, the CISO wrote a note that captures the governance failure more precisely than any technical post-mortem could.

“We just paid \$4.7 million to learn that \$1.2 million was reasonable.”

The ransomware had entered through an unprotected legacy device because endpoint detection had not been deployed across all endpoints. The attackers moved laterally across the network because weaknesses in identity governance left orphaned administrator accounts active. Initial access had come through a supplier, because the organization had no mature third-party risk programme and no enforceable security requirements for that vendor relationship.

Every gap exploited had been identified. Each had been costed. Each had been risk-assessed. Each had been denied. After the incident, the board asked why the controls were not in place. The answer was given directly. The follow-up question, who denied the funding, was met first with silence, then with the acknowledgment that the denial had occurred at the board level. The CFO said they did not understand the risk at the time.

“The risk assessment was in the request. Page 4.”

This exchange is the centre of the matter. The risk existed, was documented, and was costed. But it was not absorbed. It existed on paper, but did not change the decision. It was technically described but was not translated into a consequence serious enough to trigger executive accountability. That is the security budget paradox. Incident costs are visible and undeniable. Prevention costs are easy to defer.

The same board that demands stronger justification before an incident will approve two, three, or four times the preventive cost after the incident, without hesitation, without further justification, and without any of the scrutiny applied to the original request. This is not rational risk management. It is reactive governance. And it is a well-documented pattern of organizational failure.

“The organization did not discover the risk after the attack. It discovered the cost of having failed to act on a risk it had already been told about.”

- The deeper lesson is not that security was right and finance was wrong. That framing is too narrow.
- The deeper lesson is that risk management failed to align decision-making with business impact, and that governance failed to ensure material risk was consciously accepted rather than passively carried into an incident.

II. The Anatomy of Failure: Six Governance and Communication Breakdowns

The ransomware scenario did not result from a single failure. It resulted from at least six compounding failures, each individually identifiable, nameable, and preventable. Understanding them separately matters because each has a corresponding governance or communication remedy available in existing international standards and frameworks.

Failure 1: Technical Risk Was Not Translated Into Business Consequences

The original budget request described controls. Controls are technical objects—boards fund outcomes. The gap between these two things is not semantic. It is structural. A request for endpoint detection sounds like a software purchase. A request to reduce the probability and blast radius of ransomware across critical operations sounds like a business resilience decision. These are the same investment, framed in entirely different governance languages.

Many cybersecurity teams have become fluent in a dialect that only other security practitioners fully understand. Vulnerability counts, patch coverage percentages, mean time to detect metrics, and control coverage ratios are meaningful within a security operations center. At a board table, they compete with revenue targets, margin discussions, strategic priorities, and capital allocation conversations. They consistently lose that competition, not because boards are irresponsible, but because the language does not connect risk to the business outcomes for which boards are accountable.

“A security team can be technically correct and still fail to influence the business. A risk assessment can be accurate and still fail to change a board decision if the message does not land in the language of consequence.”

The NIST Cybersecurity Framework 2.0, released in February 2024, addresses this directly through its new ‘Govern’ function, added as the overarching framework category above all others. Govern explicitly requires that cybersecurity risk management outcomes be understood by organizational leadership, be connected to the enterprise risk appetite, and be embedded in business decision-making processes. This is not a technical requirement. It is a governance requirement, and it exists precisely because the translation failure described here is endemic across the industry.

Failure 2: Documentation Was Mistaken for Communication

The risk assessment was on page 4 of the budget submission. It was accurate, technically sound, and present. And it changed nothing.

This reflects a deeply embedded assumption within cybersecurity practice: that documentation equals communication, and that communication equals understanding. Neither equivalence holds. A risk buried inside a budget request is not the same as a risk presented directly, clearly, and in the decision-maker’s own language. ISO 31000, the international standard for risk management principles and guidelines, is explicit on this point. Its communication and consultation principle requires that risk information be actively exchanged and shared with stakeholders, not merely made available in a document.

Active communication means understanding your audience, using language and framing that resonate with their decision-making context, and confirming that the message has been received and understood, not simply transmitted. Documentation fulfils a compliance function. Communication

fulfils a governance function. Both are necessary. They are not the same thing, and treating one as a substitute for the other is a governance failure with real financial consequences.

Failure 3: Risk Acceptance Was Never Made Explicit

When the board denied the budget request, it did not formally accept the cyber risk that the denied controls were intended to address. This is the most consequential governance failure in the entire scenario. The denial removed the investment. It did not remove the exposure. The organization continued to carry the risk, untreated, for seven months, without any formal record of having decided to do so.

COSO ERM, the enterprise risk management framework maintained by the Committee of Sponsoring Organizations of the Treadway Commission, requires that risk responses be selected consciously, documented, assigned to owners, and reviewed periodically. Accepting a risk is one of four legitimate governance responses, alongside avoidance, reduction, and sharing. But it must be a decision, not the passive result of a budget denial.

The difference matters enormously. A denied control without explicit risk acceptance creates future confusion, post-incident blame displacement, and organizational amnesia about who knew what, when. A denied control with formal risk acceptance creates accountability, visibility, and an audit trail that protects both the organization and its leaders.

Failure 4: Cyber Risk Was Siloed Away From Enterprise Risk Governance

The budget request went through a finance approval process. It did not go through an enterprise risk governance process. This is a design failure, not an individual failure, and it is far more common than most organizations acknowledge.

When cybersecurity investment decisions are treated as technology procurement decisions rather than risk governance decisions, they are evaluated on entirely different criteria, by different people, with different success metrics. A CFO evaluating a \$1.2 million technology spend asks whether the expected return justifies the investment. An enterprise risk committee evaluating a \$1.2 million risk treatment asks whether the untreated exposure is acceptable and, if not, what carrying it will cost.

COBIT 2019, the IT governance framework developed by ISACA, explicitly addresses this by requiring that cyber and IT risks be integrated into the organization's overall enterprise risk management structure. Risks that exist only in IT dashboards and security reports are not governed. They are filed.

Failure 5: No Financial Quantification Was Applied to the Risk

The risk assessment described threats and controls. It apparently did not provide the board with a credible range of financial impact for the untreated exposure. This is the single most correctable failure in the scenario, and the one most likely to change the outcome if addressed.

The FAIR framework, Factor Analysis of Information Risk, maintained as an international standard by The Open Group, is the most established quantitative model for cyber risk. It produces dollar-denominated risk estimates that boards and executives can use directly in investment decisions. Its core analytical structure asks: how often does a threat event like this successfully occur against organizations with these specific control gaps, what is the likely financial impact per event, and what is the resulting annualized loss expectancy? Applied to the ransomware scenario, a properly constructed FAIR model would have produced a range of estimated annual loss exposure from \$2 million to \$5 million, compared to a \$1.2 million treatment investment. That is not a security argument. That is a business case. And it is an extraordinarily clear one.

According to the 2025 State of Cyber Risk Management report published by the FAIR Institute, nearly 45% of organizations now use or plan to use FAIR for cyber risk quantification. Among those who have adopted it, 90% report success, with the primary benefit identified as improved business alignment rather than technical security improvements. FAIR is not a security tool. It is a communication and governance tool built on security risk data.

Failure 6: The Cultural Default Was Warning, Not Advisory

Many cybersecurity programmes have, over time, adopted a cultural posture that resembles a department of warning labels more than a strategic advisory function. They communicate what is wrong, what is missing, what violates policy, and what should not be done. These warnings may be technically accurate. Over time, however, they train the business to hear security as background noise, something that exists to document what went wrong after it goes wrong, rather than a function that helps the organization make better risk decisions before losses occur.

The analogy is uncomfortable but instructive. Some security communication operates at the level of cautionary labels printed on consumer products: do not use a hairdryer in a shower, remove a child before folding a stroller. Technically correct. Strategically meaningless. Providing no basis for trade-off analysis, no connection to business consequences, and no decision support. Security teams that primarily communicate warnings eventually lose influence. Security functions that communicate business consequences, translate risk into executive language, and present decision options rather than prescriptive conclusions become strategic advisors.

This is not a soft aspiration. It is a measurable governance outcome. The organizations that have made this shift report better budget outcomes, stronger board engagement, and materially better risk postures. The cultural shift is also a capability shift, and it begins with understanding that the goal is not to say no more loudly. The goal is to make risk visible in the language of those accountable for it.

III. The Standards That Already Had the Answer: What Was Available and Why It Was Not Applied

One of the more significant dimensions of the ransomware scenario is that the governance and communication tools required to prevent it were already in place at the time of the denied request. They are not emerging standards awaiting maturation. They are established, internationally recognized frameworks that have been available for years, in some cases for decades. Understanding what each framework offers and how it maps to the specific failures in the scenario is essential for organizations seeking to avoid the same outcome.

Failure Mode	Type	Standard That Addresses It
Technical risk is not translated into business consequences	Communication	NIST CSF 2.0 (Govern function), FAIR
Documentation mistaken for communication	Communication	ISO 31000 (Communication and Consultation)
Risk acceptance is never made explicit	Governance	COSO ERM, ISO 27001 (Risk Treatment Plan)
Cyber risk is siloed from enterprise governance	Governance	COBIT 2019, COSO ERM
No financial quantification applied	Communication	FAIR (Open FAIR), ISO 27005
Cultural default was a warning, not advisory	Culture	NIST CSF 2.0 (Govern), COSO ERM (Culture)

NIST CSF 2.0: The Govern Function Reframes the Governance Question

The most significant development in NIST CSF 2.0 was the addition of Govern as the overarching function under which all others now operate. Govern requires that organizations establish a cybersecurity risk management strategy, clearly define roles and responsibilities at the executive and board levels, and integrate cybersecurity outcomes with enterprise risk management processes. In the ransomware scenario, CSF 2.0 compliance at the Govern level would have required the budget request to be evaluated as a risk management decision, not a technology procurement, with documented risk appetite alignment, clear ownership assignment, and board-level accountability for the decision, regardless of whether it resulted in investment or formal risk acceptance.

COSO ERM: Risk Must Be Owned, Not Merely Acknowledged

COSO ERM's five components, governance and culture, strategy and objective-setting, performance, review and revision, and information and communication, collectively require that risk management be a continuous, enterprise-wide discipline, not a periodic security review. Its risk response selection principle requires that every material risk have an explicitly chosen treatment, assigned to a named owner with a review timeline. The CFO's statement that they did not understand the risk at the time is precisely what COSO ERM is designed to prevent. Its information and communication component requires that risk information be communicated in a form that enables the recipient to fulfil their governance role, not simply that the information was made available somewhere in the document set.

FAIR: The Framework That Makes the Business Case Self-Evident

FAIR does something that most security frameworks deliberately avoid: it produces a number. Not a color on a heat map, not a severity rating, and not a list of controls, but a dollar amount with a probability distribution. For the ransomware scenario, a properly constructed FAIR model would have asked: how often does ransomware successfully execute in organizations with these specific control gaps, what is the likely financial impact per event, including direct recovery costs, indirect operational losses, regulatory exposure, and reputational harm, and what is the annualized loss expectancy?

The answers to those questions, presented in a board submission, would have made the cost-benefit calculation transparent and immediate. A \$1.2 million prevention investment against a \$2 million to \$5 million annualized loss exposure is not a difficult business case to make. The reason it failed to be persuasive was that it was never framed in those terms. Nearly 45% of organizations now use or plan to use FAIR, with 90% reporting success, defined primarily as improved business alignment.

ISO 27001 and ISO 27005: Risk Treatment Is a Formal Act, Not a Default

ISO 27001 requires that organizations complete a formal risk treatment plan in which every identified risk has an explicitly chosen response, and every accepted risk is formally signed off by authorized management. ISO 27005 provides risk management guidance specifically for information security and further requires that risk acceptance criteria be defined, documented, and applied consistently. In this scenario, the absence of a formal risk treatment plan meant the organization could deny a control without explicitly triggering any governance obligation to accept the residual risk. ISO 27001 would have changed that. Every denied control would have generated a risk acceptance record, signed by the authorizing executive, with a documented rationale and a scheduled review date.

ISO 31000: Communication Is an Active Obligation, Not a Passive One

ISO 31000 defines risk communication not as the act of producing reports or submitting requests, but as an ongoing, iterative process of exchanging and sharing information with stakeholders to ensure risk is understood by those who need to make decisions about it. This includes not just transmitting information but confirming understanding, adapting communication style to the audience, and creating feedback mechanisms that allow decision-makers to ask questions, challenge assumptions, and engage meaningfully with the risk picture. The page 4 problem is an ISO 31000 problem. A risk assessment included in a budget document has been transmitted. It has not been communicated.

COBIT 2019: IT Risk Belongs in the Enterprise Risk Register

COBIT 2019 defines the governance system for enterprise IT, and one of its core requirements is that IT-related risks, which now encompass all material cybersecurity risks, form part of the enterprise risk register rather than being maintained in separate security systems or reports. When cybersecurity risk lives only in security dashboards and technology reports, it is invisible to the governance mechanisms that could act on it. COBIT 2019 requires that this separation be eliminated at the governance level, where risk ownership, accountability, and treatment decisions are made.

IV. The Global Context: This Is Not an Edge Case

The ransomware scenario is not a cautionary tale about one organization’s governance failure. It is a representative example of a pattern playing out at scale across industries, geographies, and organization sizes, with increasing frequency and financial severity.

GLOBAL CYBER GOVERNANCE AND FINANCIAL DATA, 2025–2026
• ransomware attacks hit 78% of companies over the past year (CrowdStrike Global Threat Report, 2026) • 52% of organizations report their average ransomware payout now exceeds their entire annual cybersecurity budget (Armis, 2026) • Ransomware incidents increased from 572 in Q1 2024 to 1,537 in Q1 2025, a 169% year-over-year rise (QBE Insurance Group) • The FBI IC3 received over 1 million cybercrime complaints in 2025, reporting \$20.9 billion in losses, a 26% year-over-year increase • Global cybercrime losses are forecast to exceed \$10.5 trillion in 2026 (Cybersecurity Ventures) • Global cybersecurity spending will reach approximately \$240 billion in 2026, a 12.5% increase, yet breach frequency continues to rise (Gartner) • Nearly 45% of organizations use or plan to use FAIR for cyber risk quantification, with 90% of adopters reporting success (FAIR Institute, 2025) • Only 1 in 5 corporate boards had a dedicated board-level cybersecurity committee as of 2024 (Gartner) • 1 in 5 SMBs that suffered a cyberattack filed for bankruptcy or closed entirely (Mastercard Global SMB Study, 2025)

The statistic that should most concern any board or executive team is this: 52% of organizations report that their average ransomware payout now exceeds their entire annual cybersecurity budget. That means more than half of all organizations are in a structural position where recovering from a single incident costs more than a full year of prevention. This is not a risk management posture. It is the absence of one.

The pattern is consistent across the global data. Organizations continue to underspend on prevention, overspend on recovery, and maintain governance structures that allow material risk to be denied without being formally accepted. The result is predictable and expensive.

“These are not statistics. They are policy failures waiting to be named.” — Cyberwar, Digital Public Infrastructure, and the New Frontline of National Security — Godfrey Kutumela

The increase in ransomware incidents from 572 to 1,537 in a single year reflects not a random escalation but a structural market dynamic: ransomware-as-a-service has lowered the cost and complexity of launching attacks to the point where criminal operators with limited technical skill can run sophisticated extortion campaigns. The attack surface has remained wide open because the governance structures that would fund its closure continue to fail in the same repeatable ways. That is the connection between the global data and the scenario. The scenario is not unusual. It is the norm.

V. Why Cybersecurity Communication Fails: The Warning Label Problem

Cybersecurity emerged as a technical discipline. Its earliest practitioners were technologists, and its first audiences were other technologists. The language it developed, the metrics it adopted, and the reporting cadences it established were all designed for an audience that shared its technical context. That audience has never been a board of directors.

As cybersecurity has grown into a board-level concern, the discipline has not consistently adapted its communication model to match its new audience. The result is a persistent mismatch between the risk information that security teams produce and the risk information that executive and board audiences need to make governance decisions. This mismatch has a structural character: it is baked into how security programmes are built, how CISOs are trained, and how risk reporting is formatted. It will not be corrected by asking individual practitioners to communicate better. It requires a systemic redesign of how security risk is framed, quantified, and presented.

The Warning Label Trap

Security teams that have fallen into this trap sound like organizational warning labels. They say: "Do not do this, that is risky, " " This violates policy, " " We warned you, " " That control is missing, " " This exception creates exposure. At first, these warnings may be valid and useful. Over time, the business learns to hear security as background noise. This function exists to document what went wrong after it goes wrong, rather than to help the organization make better decisions before losses occur.

The problem is not that the warnings are wrong. The problem is that warnings without consequence estimates, trade-off analysis, or decision options are not governance inputs. They are compliance artifacts. A board that has been told repeatedly that endpoint coverage is incomplete but has never been shown what a ransomware event in that environment would cost to recover, has not been given decision-grade information. It has been given a warning label.

The Consequence Gap

The most common failure in cybersecurity communication is the consequence gap: the gap between the technical description of a risk and its business meaning. Security teams are experts at describing vulnerabilities, control gaps, and threat vectors. They are often far less practiced at answering the question that boards actually need answered: so, what does this mean for us, specifically, in financial and operational terms?

FAIR addresses this gap directly. Its foundational premise is that every risk description must ultimately be convertible into a financial impact range to be actionable for decision-making. "Ransomware is a major concern" is not actionable. "Ransomware executing on unmanaged endpoints, spreading through orphaned administrator accounts, and affecting core business systems carries an estimated recovery cost of \$2 million to \$5 million, with a 40% to 60% probability of occurrence within 24 months given current control coverage" is actionable. The substance is the same. The governance utility is entirely different.

What the Business Actually Needs From Security

A board does not need a catalogue of vulnerabilities. A board needs to understand which cyber risks could materially affect enterprise value, operational continuity, legal exposure, customer trust, or strategic execution, and what the organization's current posture is against each of those risks.

A CFO does not need a technical briefing on endpoint detection architecture. A CFO needs to understand whether the absence of endpoint detection could turn a \$1.2 million prevention decision into a \$4.7 million recovery event.

A CEO does not need a lecture on identity governance principles. A CEO needs to know whether identity weaknesses could allow an attacker to move from one compromised account into the systems that run the core business.

An audit and risk committee does not need a vendor questionnaire completion rate. It needs to know whether any of the organization's key suppliers could become the unmanaged entry point through which the enterprise suffers operational disruption, data loss, regulatory scrutiny, or customer harm.

The substance of the risk may be technical. The meaning of the risk is business. Mature cybersecurity communication consistently, clearly, and without requiring the audience to perform the translation itself.

VI. The Governance Shift That Changes Everything: Formal Risk Acceptance

There is one governance change that, implemented consistently, transforms the cybersecurity investment conversation more reliably than any other. It is simple, it costs nothing to implement beyond organizational will, and it is already required by COSO ERM, ISO 27001, ISO 31000, and NIST CSF 2.0. It is the requirement for formal risk acceptance for every denied material cybersecurity control.

“When decision-makers had to sign their names next to a statement such as: ‘Accepted risk: unprotected legacy endpoints, estimated breach impact \$2 million to \$4 million’, the discussion changed immediately.”

This is not a punitive mechanism. It is not designed to embarrass decision-makers or coerce approvals that the business legitimately cannot afford. It is designed to ensure that when the business chooses not to invest in a material control, it does so consciously, with a documented understanding of the exposure it is carrying, with a named owner for that decision, and with a scheduled review date.

Why This Changes the Conversation

The change is psychological as much as procedural. Nobody signs their name to a statement acknowledging \$4 million in untreated exposure without engaging at a different level with the underlying risk than by simply declining a line item. The act of signing triggers a form of ownership that passive denial does not. After introducing formal risk acceptance requirements, organizations consistently report the same outcome: discussions that previously ended quickly with denials now involve more questions, more challenge, more negotiation over compensating controls, and more frequent partial approvals. The risk did not change. The accountability did.

The Institutional Memory Function

Formal risk acceptance also addresses one of the most damaging governance problems posed by cyber incidents: post-incident amnesia. In this scenario, the board’s question about why the controls were not in place, and the silence that followed, reflected an institutional memory failure. Nobody remembered denying the request, nobody recalled the reasoning, and nobody could identify who had been accountable for the decision.

A cyber risk acceptance register prevents this. It creates a living record of which risks are being carried, under what assumptions, by whom, since when, and under what conditions they are to be reviewed. When an incident occurs, the register answers every post-incident governance question immediately and accurately. When a risk crystallizes, the register makes clear who accepted it, why, and what they expected to happen if the decision proved wrong. This is institutional memory by design rather than by accident.

The Fiduciary Dimension

There is a fiduciary dimension that has become increasingly significant as regulators and courts have become more attentive to board-level cybersecurity governance. The SEC’s 2023 cybersecurity disclosure rules require public companies to disclose material cybersecurity risks and incidents and to describe board-level oversight of cybersecurity risk management. The EU NIS2 Directive, effective October 2024, imposes analogous obligations across the European Union.

In this regulatory context, a board that denied a material cybersecurity investment without formal risk acceptance is in a meaningfully different legal and governance position from one that denied it with full risk acceptance documentation. The former may be unable to demonstrate that the governance process was adequate. The latter can show that the risk was understood, considered, formally accepted, and assigned to a named owner. That distinction is becoming increasingly material, not only as a matter of organizational hygiene but as a matter of legal and regulatory exposure.

VII. Decision-Grade Risk Communication: A Practical Framework

Improving cybersecurity communication requires more than good intentions. It requires a structured approach that consistently translates technical risk information into decision-grade inputs for executive and board audiences. The following framework provides that structure, grounded in the standards described above and in observed good practice from organizations that have successfully made this transition.

Step 1: Lead With the Business Scenario, Not the Control

TRANSLATION: FROM CONTROL LANGUAGE TO BUSINESS CONSEQUENCE LANGUAGE

INSTEAD OF: “We need endpoint detection.”

SAY: “We have endpoint visibility gaps that could allow ransomware to execute on unmanaged devices and spread laterally before containment, creating a credible multi-day operational disruption.”

INSTEAD OF: “We need identity governance.”

SAY: “Orphaned and over-privileged accounts exist that could allow an attacker who has gained initial access to move through core business systems before detection, amplifying the impact of any breach.”

INSTEAD OF: “We need third-party risk management.”

SAY: “Key vendors have access to our environment under requirements we cannot currently verify or enforce. Any one of those relationships could become an unmanaged entry point into our systems.”

The principle in each case is identical. Do not lead with the tool. Lead with the business consequence. Connect the technical gap to the business outcome it threatens, and name that outcome specifically in terms of the business function, revenue stream, customer obligation, or regulatory exposure that is affected.

Step 2: Quantify Exposure in Financial Ranges

Using the FAIR framework or a comparable quantification methodology, provide decision-makers with a financial impact range for the untreated risk. Cyber risk does not require false precision. It requires decision-useful estimates. For example: estimated disruption cost of \$2 million to \$4 million, recovery timeline of three to seven business days, affected systems including payment processing and

customer service operations, confidence level of medium based on current threat intelligence and incident response maturity. This comparison of prevention cost against plausible loss exposure is a business case, not a security argument. It requires nothing that a CISO cannot provide, and nothing a board cannot understand.

Step 3: Present Treatment Options, Not Just Preferred Solutions

STANDARD THREE-OPTION TREATMENT STRUCTURE

Option A — Full Investment (\$1.2M): Materially reduces the likelihood and blast radius. Six-month implementation. Residual risk: moderate and declining.

Option B — Phased Investment (\$600K in Year 1): Prioritizes highest-risk assets first. Twelve-month implementation. Higher residual risk during transition, with a committed plan to close.

Option C — Defer: No immediate spend. Current exposure remains unchanged. Required action: formal risk acceptance with documented rationale, named owner, review date, and estimated exposure range of \$2M to \$4M.

Presenting three options accomplishes two things simultaneously. It gives leadership a genuine choice rather than a binary approve or deny dynamic, and it makes the deferral option visible and named in a way that passive denial does not. Deferral is no longer a default outcome. It is a consciously chosen option with documented consequences.

Step 4: Separate Risk Ownership From Control Ownership

Security owns the control recommendation. The business owns the risk impact. This separation is critical and is frequently overlooked. Endpoint control failure may affect operations. Identity failure may affect enterprise systems. Third-party failure may affect procurement and service delivery. Data protection failure may affect legal and compliance obligations.

The CISO can identify these connections and quantify the exposure, but the executive accountable for each business function is the appropriate owner of the business risk, not the CISO alone. Assigning business risk ownership to the affected executive creates a new advocate for the security investment within the business, someone whose own performance is affected by the risk, and distributes accountability appropriately so that a cyber incident is understood as a business risk that was jointly owned and either treated or formally accepted.

Step 5: Build and Maintain a Cyber Risk Acceptance Register

Every denied or deferred material cybersecurity control should be recorded in a cyber risk acceptance register. That record should include what was denied, what risk remains, the estimated business impact range, the reason for deferral, the decision owner, the compensating controls currently in place, the scheduled review date, and the conditions that would trigger an early review. The register should be maintained by the risk or governance function, not solely by the security team, and should be reviewed by the audit and risk committee at least quarterly. It should connect directly to the enterprise risk register so that cyber risk is visible in the same governance context as operational, financial, legal, and strategic risk.

Step 6: Report Residual Risk, Not Only Activity

Board reporting should shift from security activity reporting to security risk reporting. The critical distinction: a security programme can be busy and still leave the enterprise materially exposed. Board-level cyber reports should answer these questions:

- What business process, revenue stream, or customer obligation could be materially disrupted by our current cyber exposures?
- How has our material cyber exposure changed since the last reporting period, and why?
- What risks are we currently carrying that we have formally accepted, and are those acceptance decisions still current?
- What is our current resilience posture against our top three cyber threat scenarios, in estimated recovery time and estimated financial cost?
- What investment decisions are required in the next period to maintain or improve our risk posture?

These questions connect security reporting to the business outcomes for which boards are accountable. They require security teams to provide decision-grade information rather than operational activity summaries, and they give boards the context they need to fulfil their governance role.

VIII. Policy Recommendations: Governance Changes That Change Outcomes

The following policy recommendations are organized by audience. They are grounded in the standards described in Section III and in the communication and governance practices described in Sections V through VII. They are sequenced from the most immediately implementable to the most structurally significant.

For the CISO and Security Leadership

1. **Adopt FAIR or equivalent financial quantification for all material risk submissions.** Lead with dollar-denominated impact ranges, not severity ratings or vulnerability counts, as the primary risk metric in every executive and board submission. This single change produces more measurable improvement in board engagement and budget approval outcomes than any other communication shift.
2. **Translate every control request into a business scenario before it reaches an executive audience.** Name the business function, revenue stream, customer obligation, or regulatory exposure at risk. Use the business consequence as the headline, and the control as the solution to that consequence.
3. **Present three treatment options consistently:** full investment, phased investment, and formal risk acceptance with explicit costs and consequences for each path. Remove the binary approve or deny dynamic from every material submission.
4. **Build and maintain a cyber risk acceptance register as a standing governance document,** reviewed quarterly by the audit and risk committee, and connected directly to the enterprise risk register.
5. **Co-present with the business executive accountable for the affected function** on all material risk submissions. This demonstrates business alignment, distributes accountability appropriately, and creates a second voice in the room that speaks from an operational rather than a security perspective.
6. **Measure your effectiveness by governance outcomes, not warning volume.** The right success metric for a mature security function is how effectively it enables better risk decisions, not how many reports it produces or how many policy exceptions it denies.

For Boards and Audit Committees

7. **Require formal risk acceptance for every denied material cybersecurity control,** with a named owner, a documented financial impact range, a review date, and any compensating controls explicitly stated. This is the highest-leverage governance change available.
8. **Establish board-level cybersecurity oversight** with at least one member holding sufficient cybersecurity literacy to evaluate risk submissions, and a formal reporting cadence separate from technology or IT reporting.
9. **Require cyber risk to appear in the enterprise risk register,** reviewed under the same governance cadence as financial, operational, and strategic risk. Cyber risk that exists only in security reports is not governed.
10. **Apply these six governance questions to every material cyber risk presentation:** what business outcome is at risk, what is the plausible loss scenario, what is the estimated financial exposure, what does the proposed investment reduce, what happens if the investment is deferred, and who formally accepts the risk if it is deferred.

11. **Require disclosure of accepted cyber risks in board minutes or audit committee records**, with the same formality applied to other significant governance decisions. Material risks accepted at the board level should be traceable in perpetuity.

For CFOs and Finance Leadership

12. **Distinguish between budget decisions and risk governance decisions.** A denied cybersecurity request that carries material risk exposure is not only a budget decision. Establish a protocol that routes material security requests through both the risk governance and financial approval processes.
13. **Require financial impact ranges alongside control costs for all material security submissions.** Every material security request should include a plausible loss estimate for the untreated risk, formatted as a range with documented assumptions. This provides the cost-benefit context necessary for a risk-informed financial decision.
14. **Integrate cybersecurity investment into the risk-adjusted capital allocation framework.** The annualized loss expectancy prevented per dollar invested is as valid a return metric as any other investment evaluation criterion. Apply it consistently to security investment decisions.

For Executive Teams

15. **Own the cyber risk associated with your business function**, not just the security controls that affect it. The consequence of a cyber incident in your area of responsibility is a business risk you carry, whether or not you initiated the security investment decision.
16. **Require regular briefings on accepted cyber risks within your area of responsibility.** Know what exposures your business function is currently carrying, under what assumptions, and as of what date those acceptance decisions were made. Treat the review of accepted cyber risks as a standing agenda item.
17. **Support a security function that is structured as a strategic advisory, not a compliance function.** The cultural shift from warning-label communication to decision-grade risk advisory requires organizational permission and leadership support. Signal clearly that security's role is to enable better risk decisions, not to document everything that could go wrong.

IX. The Cultural Shift Required: From Warning Label to Strategic Advisor

The governance changes described in the preceding sections are necessary but not sufficient on their own. They will not sustain themselves in an organizational culture that has not made a deeper shift in its understanding of the relationship between security and the business. That cultural shift has three distinct dimensions.

For Security Teams: Measure Success by Governance Outcomes, Not Warning Volume

Security teams must stop measuring effectiveness by how many warnings they issued, how many reports they produced, how many vulnerabilities they identified, or how many policy exceptions they denied. These are activity metrics. They measure effort, not impact.

The right success metric for a mature security function is this: how effectively did we enable the business to make better risk decisions? Did leadership understand the material risks? Were those risks formally accepted or treated? Were they denied investments accompanied by risk acceptance records? Did our communication change outcomes?

Organizations that have made this shift report measurably better budget outcomes, more engaged board audiences, and materially stronger risk postures. The security function that earns its place at the business decision-making table is the one that speaks the language of that table.

For Boards: Cybersecurity Is a Governance Discipline, Not a Technology Problem

The framing of cybersecurity as a technology problem has been one of the most damaging governance assumptions of the past two decades. It has produced boards that delegate cyber oversight entirely to the CISO or CTO, that evaluate security investment purely as a technology cost, and that discover their governance gap only when an incident forces it into view.

Cybersecurity is a governance discipline. It involves risk identification, assessment, treatment decision-making, ownership assignment, residual risk monitoring, and periodic review. These are governance activities. They require governance structures, not only technical infrastructure. Every board should be able to answer these questions without first consulting the CISO: what are our top three material cyber risks; what is our current posture against each; which risks are we formally carrying, and who accepted them; and when were those decisions last reviewed? Boards that cannot answer these questions have a governance gap. Not a technology gap.

For Organizations: Breaking the Prevention Paradox Structurally

The prevention paradox, the organizational tendency to defer security investment until an incident makes it unavoidable, is not irrational at the individual decision-making level. It is the rational result of a governance structure that makes prevention costs visible and certain while making incident costs invisible and hypothetical.

The structural fix is to make both costs equally visible, equally certain, and equally assigned to named owners. When prevention costs are documented as investments with quantified returns, and when deferred prevention generates formal risk acceptance records with named executives as owners, the asymmetry dissolves. The calculation is no longer prevention cost versus zero. It is the prevention cost versus the formally accepted exposure range, with a named owner standing behind the

acceptance. That is a fundamentally different decision environment, and it produces fundamentally different outcomes.

“No organization should wait for a \$4.7 million recovery event to create the governance conditions that would have justified a \$1.2 million prevention investment. Those conditions are available today, in existing standards, with existing tools.”

X. Conclusion: The Risk Was on Page 4. It Should Have Been on the Cover.

The ransomware scenario that opened this paper is powerful not because the attack was sophisticated, but because it was entirely predictable. Every gap that was exploited had been identified, assessed, costed, and submitted for funding. The organization did not discover the risk after the attack. It discovered the cost of having failed to act on a risk it had already been told about.

The original budget request was \$1.2 million. The recovery cost was \$4.7 million. Emergency post-incident funding reached \$3 million. The exploited weaknesses were exactly those identified in the denied request: endpoint detection gaps, identity governance weaknesses, and third-party risk exposure. The CFO said they did not understand the risk at the time. The risk was on page 4.

The failure had six dimensions, each of which can be addressed individually using existing frameworks and standards. Technical risk was not translated into business consequences. Documentation was mistaken for communication. Risk acceptance was never made explicit. Cyber risk was siloed from enterprise governance. No financial quantification was applied. And the cultural default was warning, not advisory. NIST CSF 2.0, COSO ERM, FAIR, ISO 31000, ISO 27001, and COBIT 2019 each address one or more of these failures directly, with implementable guidance that is available to every organization right now.

The lesson is not that security was right and finance was wrong. The deeper lesson is that risk management failed to align decision-making with business impact, and governance failed to ensure that material risk was consciously accepted rather than passively carried into an incident that was always going to be more expensive than the prevention it replaced.

“The most important governance shift costs nothing to implement and is already required by multiple international standards: require formal risk acceptance for every denied material cybersecurity control. Nobody denies a risk they are forced to formally own.”

Cybersecurity teams that only communicate threats eventually lose influence. Security functions that communicate business consequences, present decision options rather than prescriptions, and build governance structures that force accountability before events make it unavoidable, become strategic advisors. They earn their seat at the decision-making table not by being technically superior but by being governance-aligned.

The future of cybersecurity leadership belongs to practitioners and organizations that can answer not just what is vulnerable, but what that means for the business, not just what control is missing, but what business outcome is exposed, and not just what security wants funded, but what loss the organization is implicitly accepting if it refuses.

Because the risk was on page 4. The governance failure was the assumption that page 4 was sufficient. And the remedy is to build structures where material risk is never buried on page 4. It is visible, it has a named owner, and it has either been formally funded or formally accepted. On the record. In writing. With a signature.

STRATEGIC RECOMMENDATIONS SUMMARY

KEY SOURCES AND REFERENCES

- NIST Cybersecurity Framework 2.0 (NIST CSWP 29, February 2024)
 - COSO Enterprise Risk Management: Integrating with Strategy and Performance (Committee of Sponsoring Organizations of the Treadway Commission, 2017, updated 2023)
 - Factor Analysis of Information Risk (FAIR), Open Group International Standard, O-RT v2.0
 - FAIR Institute: 2025 State of Cyber Risk Management Report
 - ISO 31000:2018 Risk Management, Guidelines (International Organization for Standardization)
 - ISO 27001:2022 Information Security Management Systems, Requirements
 - ISO 27005:2022 Guidance on Managing Information Security Risks
 - COBIT 2019 Framework: Governance and Management Objectives (ISACA)
 - Armis: State of Cyberwarfare Report 2026
 - CrowdStrike: 2026 Global Threat Report
 - QBE Insurance Group: Ransomware Trends Report 2025 and 2026
 - FBI Internet Crime Complaint Center (IC3) Annual Report 2025
 - Gartner: Cybersecurity Spending Forecast 2025 and 2026
 - Cybersecurity Ventures: Global Cybercrime Cost Projections 2026
 - C-Risk: FAIR, the Industry Standard for Cyber Risk Quantification
 - Mastercard Global SMB Cybersecurity Study 2025
 - SEC Cybersecurity Disclosure Rules (17 CFR Parts 229 and 249, effective December 2023)
 - EU NIS2 Directive (Directive 2022/2555, effective October 2024)
-

ABOUT THE AUTHOR

Godfrey Kutumela is the CEO and Lead Cybersecurity Practitioner at Nucleus Systems. His work spans cybersecurity strategy, digital public infrastructure security, critical infrastructure risk, and board-level cyber governance advisory for clients across the public and private sectors. He is the author of “Cyberwar, Digital Public Infrastructure, and the New Frontline of National Security” (April 2026) and “Reframing Critical Infrastructure Risk in the Age of Cyberwar” (May 2026). This paper is the third in that series.

ABOUT NUCLEUS SYSTEMS

Nucleus Systems is a cybersecurity advisory practice that works at the intersection of security, governance, and business consequences. The firm supports boards, executive teams, and security leaders in building the governance structures, communication frameworks, and risk management capabilities needed to make better security decisions before incidents make them unavoidable.